

SecTask - Documento Simplificado de Arquitectura e Implementación

1. Información General del Proyecto

Nombre del Proyecto

SecTask

Tipo de Proyecto

Aplicación web de gestión de tareas con implementación de requerimientos no funcionales (RNF) de seguridad.

Objetivo General

Desarrollar un sistema web para gestión de tareas implementando controles básicos de seguridad informática y buenas prácticas de desarrollo seguro.

Objetivos Específicos

- Implementar autenticación segura de usuarios.
 - Proteger el sistema contra vulnerabilidades comunes.
 - Registrar eventos importantes del sistema.
 - Aplicar mecanismos básicos de seguridad web.
 - Realizar pruebas de seguridad sobre la aplicación.
-

2. Descripción General del Sistema

SecTask es una plataforma web donde usuarios autenticados podrán:

- Registrarse.
- Iniciar sesión.
- Crear tareas.
- Editar tareas.
- Eliminar tareas.

- Marcar tareas como completadas.

El enfoque principal del proyecto será implementar y demostrar controles de seguridad web.

3. Arquitectura del Sistema

Arquitectura General

El sistema utilizará una arquitectura cliente-servidor sencilla de 3 capas.

3.1 Frontend

Tecnologías:

- HTML5
- CSS3
- JavaScript
- Bootstrap

Funciones:

- Formularios de login y registro.
 - Gestión visual de tareas.
 - Interfaz administrativa básica.
-

3.2 Backend

Tecnologías:

- Node.js
- Express.js

Funciones:

- API REST.
- Autenticación.
- Validación de datos.
- Manejo de sesiones.
- Seguridad de la aplicación.

3.3 Base de Datos

Tecnología:

- MySQL

Funciones:

- Almacenamiento de usuarios.
 - Almacenamiento de tareas.
 - Registro de logs.
-

4. RNF de Seguridad Implementados

RNF 1 - Validación y Sanitización de Entradas

Objetivo

Evitar ataques de inyección y ejecución de código malicioso.

Implementación

- Validación de formularios.
- Sanitización de entradas.
- Consultas parametrizadas.

Herramientas

- express-validator

Vulnerabilidades mitigadas

- SQL Injection
 - Cross Site Scripting (XSS)
-

RNF 2 - Logs de Auditoría

Objetivo

Registrar eventos importantes del sistema.

Eventos registrados

- Inicio de sesión.
- Intentos fallidos.
- Creación y eliminación de tareas.
- Errores importantes.

Herramientas

- Winston
- Morgan

Beneficios

- Trazabilidad.
 - Monitoreo de actividad sospechosa.
-

RNF 3 - Recuperación de Contraseña con Token Expirable

Objetivo

Permitir recuperación segura de credenciales.

Funcionamiento

1. Usuario solicita recuperación.
2. Sistema genera token temporal.
3. Token expira después de 10 minutos.
4. Usuario cambia la contraseña.

Herramientas

- JWT
- UUID

Vulnerabilidades mitigadas

- Reutilización de enlaces.
 - Uso indebido de tokens.
-

RNF 4 - Implementación de Controles OWASP Top 10

Objetivo

Mitigar vulnerabilidades comunes en aplicaciones web.

Controles implementados

- Protección contra SQL Injection.
- Protección contra XSS.
- Configuración segura del servidor.
- Rate limiting.
- Manejo seguro de errores.

Herramientas

- Helmet
 - express-rate-limit
 - dotenv
-

5. Funcionalidades del Sistema

5.1 Gestión de Usuarios

Registro

El usuario podrá:

- Crear cuenta.
 - Registrar correo electrónico.
 - Crear contraseña.
-

Inicio de Sesión

El usuario podrá:

- Iniciar sesión con email y contraseña.

Características:

- Contraseñas cifradas con bcrypt.
 - Uso de JWT.
-

Recuperación de Contraseña

El usuario podrá:

- Solicitar recuperación.
 - Cambiar contraseña mediante token temporal.
-

Cierre de Sesión

El sistema cerrará la sesión del usuario.

5.2 Gestión de Tareas

Crear Tarea

El usuario podrá:

- Crear tareas.
- Agregar título.
- Agregar descripción.

Editar Tarea

El usuario podrá modificar:

- Título.
- Descripción.
- Estado.

Eliminar Tarea

El usuario podrá eliminar tareas propias.

Completar Tarea

El usuario podrá marcar tareas como completadas.

6. Modelo de Base de Datos

Tabla users

Campos:

- id
- username
- email
- password_hash
- created_at

Tabla tasks

Campos:

- id
 - user_id
 - title
 - description
 - status
 - created_at
 - updated_at
-

Tabla audit_logs

Campos:

- id
 - user_id
 - action
 - timestamp
-

Tabla password_reset_tokens

Campos:

- id
 - user_id
 - token
 - expires_at
-

7. API REST

Autenticación

POST /api/auth/register

POST /api/auth/login

POST /api/auth/logout

POST /api/auth/forgot-password

POST /api/auth/reset-password

Tareas

GET /api/tasks

POST /api/tasks

PUT /api/tasks/:id

DELETE /api/tasks/:id

8. Seguridad Implementada

bcrypt

Uso:

Hash de contraseñas.

JWT

Uso:

Autenticación mediante tokens.

Helmet

Uso:

Protección de headers HTTP.

Rate Limiting

Uso:

Limitar intentos de login y prevenir fuerza bruta.

9. Casos de Prueba de Seguridad

Caso 1 - SQL Injection

Entrada:

' OR 1=1 --

Resultado esperado:

Solicitud bloqueada.

Caso 2 - XSS

Entrada:

Resultado esperado:

Código sanitizado.

Caso 3 - Fuerza Bruta

Escenario:

Múltiples intentos de login.

Resultado esperado:

Rate limiting activado.

Caso 4 - Token Expirado

Escenario:

Uso de token vencido.

Resultado esperado:

Acceso denegado.

10. Herramientas para Hacking Ético

Herramientas:

- OWASP ZAP
- Burp Suite
- Postman

Pruebas:

- Escaneo de vulnerabilidades.
 - Manipulación de peticiones.
 - Pruebas de XSS y SQL Injection.
-

11. Librerías y Dependencias

Backend

- express
 - bcrypt
 - jsonwebtoken
 - express-validator
 - helmet
 - express-rate-limit
 - dotenv
 - winston
 - morgan
 - mysql2
-

Frontend

- bootstrap
 - axios
-

12. Estructura del Proyecto

/backend
/controllers
/routes
/middlewares
/models
/logs
server.js

/frontend
/css
/js
index.html

/database
schema.sql

/docs
evidencias
pruebas

13. Metodología de Desarrollo

Fases:

1. Diseño de base de datos.
 2. Desarrollo backend.
 3. Desarrollo frontend.
 4. Implementación de RNF.
 5. Testing.
 6. Pruebas de seguridad.
 7. Documentación.
-

14. Requisitos Funcionales

RF1 - Registro de usuarios.

RF2 - Inicio de sesión.

RF3 - Gestión de tareas.

RF4 - Recuperación de contraseña.

RF5 - Visualización básica de logs.

15. Requisitos No Funcionales

RNF1 - Validación y sanitización de datos.

RNF2 - Auditoría de eventos.

RNF3 - Recuperación segura de contraseña.

RNF4 - Protección contra vulnerabilidades OWASP.

16. Resultados Esperados

- Aplicación funcional.
 - Implementación de RNF de seguridad.
 - Vulnerabilidades mitigadas.
 - Evidencia de pruebas de seguridad.
 - Documentación técnica completa.
-

17. Conclusión

SecTask será una aplicación web sencilla enfocada en demostrar la implementación práctica de controles de seguridad informática y criptografía aplicada en un entorno realista de desarrollo web.